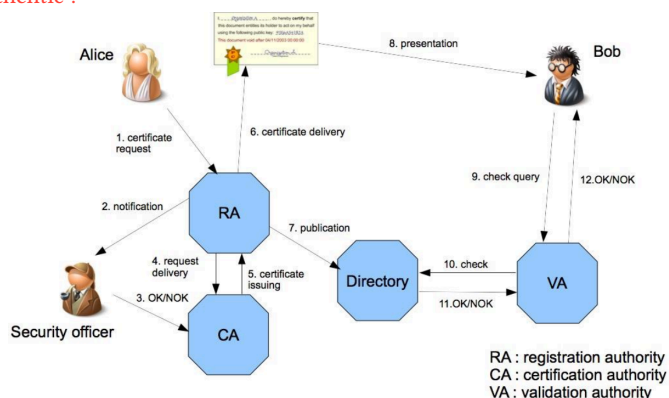


IT Focus data management, confidentiality. **Operational Technology (OT)** **Focus:** physical processes, availability, safety. Stricter uptime/deterministic requirements (real-time operations). Involve critical sys with severe physical consequences. **Challenge:** skill gaps + miscommunication IT/OT **CS Threats:** Malware, Ransomware, Advanced Persistent Threats (stealthy/continuous hacking), Insider Threat. **How to secure:** ntw segmentation (Separation of OT and IT), limit threat lateral movement, reduce risk unauthorized access), defense-in Depth strat (FW, IDS, encryption), access control, secure communication. **Industrial Control System (ICS)** Inf sys to control industrial processes. Includes SCADA. **Security Challenge:** Legacy protocol/sys => isolation/segmentation, limited visibility/patch management => enhance visibility, convergence IT/OT => securing external connection, supply chain risks/human error => access control and containing incident spread. **Distributed Control System (DCS)** ICS architecture where control is distributed between entities **Supervisory Control And Data Acquisition (SCADA)** control and gather/process data from control geographically dispersed assets. **Programmable Logic Controller (PLC)** Programmable industrial computer that executes user-defined logic for I/O control, timing, counting, PID regulation, communication. **Remote Terminal Unit (RTU)** Computer with radio interfacing for remote sites without wired comms, to communicate with field equipment. **Intelligent Electronic Device** Microprocessor-based controller for power equipment (breakers, transformers, capacitors), integrates sensing/control/communication on device itself. **Function Block Programming** Graphical PLC programming language, links input/output variables through connected function blocks. **Legacy OT** lvl 0/1 devices: long lifecycle (10-20+ yrs), ruggedized/fanless/low-power, harsh conditions, strict SLA. Hard to patch/update => vulnerability accumulation. **Risk** Effect of uncertainty on obj. **Management:** Must be repeatable, scalable and transferable. Identify risk => compare to org accepted risk threshold => avoid/transfer/mitigate/accept. **Purdue Model (PERA)** outlines interaction IT/OT. Enable better comm. IT/OT. Aims to reduce risk of threats. **Ivl0:** instrument to sensing or acting on physical process (sensors, pumps, valves). **Ivl1:** intelligent device to sense/monitor/control physical process (PLC, SIS, RTU). **Ivl2:** Control sys to supervise/monitor physical process (HMI, SCADA). **Ivl3:** operation sys to manage/control production flow (AD, File servers, Historians). **DMZ:** buffer btwn ICS/external ntw (Proxy, Mail, Replica). **Ivl4:** enterprise ntw (data exchange, business-to-business, business-to-client). **Governance Hierarchy** External/internal influence => Policy (high lvl declaration = why) => Control obj (obj of policy) => Standard (what to do to apply policy, mandatory) => Guideline (recommended way to meet standard, optionnal) => Control (implementation of standard) => Procedure (how to implement control). Risks/Threats justify Controls; Metrics measure Control effectiveness. **Standardization Goals** Maximize business benefits, institutionalize best practices in standards, be compliant (contract obligations, laws, regulation). **Benefits:** ensure fulfillment of necessary quality, preferred access to market, defines obligations, give guarantees. **Standard vs Certification Standard:** document describing best way of doing something (IEC, NIST, IEE, ISO). **Certification:** written assurance by an independent body that specific requirements (a standard) are met. **Critical Infrastructure** Not the same btwn USA/UE/CH. Energy (gas/power/oil supply), Finances, Inf&Communication (media, postal, telecom), Public Administration (government, justice, reasearch), Pulic Health (hospital, laboratory), Public Safety (army, emergency services), Transport (air, rail, road), Food and Water, Waste disposal. **Impact of regulations on OT Obligations:** Policies on risk analysis and inf sys security, Incident handling, Business continuity (backup management/disaster recovery/crisis management), Supply chain security, Security in ntw and inf sys (acquisition/development/maintenance/vulnerability handling and disclosure), Policies and procedures to assess effectiveness of cs risk-management measures, Basic hygiene practices and cs training, Policies and procedures regarding use of cryptography, Human resources security, access control policy, asset management, use of MFA and secured emergency communications, coordinated vulnerability disclosure policy. **Impact:** fines up to 2% global revenue. CH: Criminal Code (data theft/unauthorized access/data damage/computer fraud). **Role of communication systems Goals:** Facilitate inf flow to improve operations efficiency. Enhance better decision making with real-time data. Promote Operational Continuity with reliable communication sys. **Requirement:** Determinism/Real-Time, Scalability, Reliability, Availability, Latency, Time Sync., Open standards/Interoperability, Security. **Why real-time:** needed for timely/accurate data processing, control actions, precision/rapid response. **Quality Of Service (QoS):** prioritize ntw traffic (critical data first), minimize delay, maintain operational efficiency and productivity. **RTOS:** combined with comm ensure efficient task management, rsc allocation, real-time perf. **WAN Requirement:** deterministic end-to-end perf (no best effort), guaranteed QoS/delay/jitter, precision time&clock, encrypted packet, fast path protection switching. **Encryption/Network Segmentation:** need for data protection against breach/unauthorized access. Access limitation to reduce risk and enhance security posture. **Use of Secure Protocols:** to ensure privacy/integrity, prevent eavesdropping. **Heterogeneity of OT Systems:** variety of device with unique specs and fct, protocols => Interoperability Challenge. **Open Standard:** ensure interoperability, facilitate communication, enhance data exchange. **Communication Protocol Classification** External (protocol relies on external security measure ?), Msg integrity ? Msg confidentiality ? Secure Authentication and Authorization ? **OT Wired Communication**

Favored for their high-speed/stable capabilities (crucial for real-time data). **Ethernet:** non-time-critical comm btwn lvl1 and lvl2. **FieldBus:** wired protocol to link lvl0 and lvl1. time critical/cost requirement **MODBUS:** client-server/master-slave arch with limited computing rsc. **simplicity, interoperability, cost-effectiveness, flexibility, wide adaption. limited bandwidth, no built-in security/redundancy, limited error handling, limited addr space, no support complex data, polling overhead, no safety/real-time** **EtherCAT:** real-time ethernet, topology agnostic, support for 2^16 devices, sync with distributed clocks. **real-time comm, cost-efficiency, scalability, flexible topology, high reliability. complex ntw design, device compatibility, integration/debugging** **OT Wireless Communication:** Flexibility and Mobility (connection without physical constraint). Need careful implementation to mitigate interference/risks. **Critical factors:** Limited energy capacity, HW constraints, Dynamic ntw, Node deployment, Fault tolerance, Latency, Data aggregation, Scalability. **Zigbee:** mesh WPAN. Roles: Coordinator(ZC) (first started node, form ntw, allow other node to join ntw, unique), Router(ZR) (routing, multiple), End device(ZED) (send/receive only, can be sleepy). **low power, low cost, scalable (up to 65k devices), 128-bit sym key. low data rate, short range.** **WirelessHART:** bi-directional industrial field communication btwn host sys and field device. Provides 2 simultaneous channels (analogue, digital). Roles: Field device, Gateway (bridge to host/backbone), Network Manager (schedules comm, routes, monitors health). **low power, scalable, time sync, TDMA, redundant transmission, frequency hopping. mid-range only.** **Security:** end-to-end encryption (128-bit AES), unique key/message, rotating join keys, common ntw key for broadcast, join key = device authentication. **Others:** 5G, Wi-Fi. **SyncE** derives clock sync from physical-layer signal edges. **PTP** GPS-based grandmaster sends timestamped packets to sync slave clocks. **Time Sensitive Network (TSN)** Deterministic data transmission. Suitable for industrial automation application. Time sync btwn devices => ensure data transmission over defined time parameters. Allow allocation/priorization of ntw bandwidth. Enhance reliability => minimize packet loss/latency. Interoperability with existing Ethernet standards. **Guard Band:** blocks new low-priority frames just before a critical time slot, so no frame overruns into it. $G_size [us] = \frac{\text{max frame size [bytes]}}{\text{link rate [Mb/s]}}$. **Air-Gapped** No physical link OT/IT (extreme segmentation). **threat mitigation, compliance, data integrity. infra cost, insider threat still possible, hard to update/maintain.** **Multi Protocol Label Switching (MPLS)** Faster than per-packet IP routing lookup. Data transport protocol based on labels, layer 2.5 (btwn L2&3 OSI). Link ip addr to label (FEC). Allow various app (VPN, traffic aggregation, QoS). Use Label Swapping Table **LSP:** path through ntw = sequence of labels, each LSR swaps label, "tunnel" w/o inspecting inner header. **LSR:** core router, high-speed label swapping. **LER:** ntw edge, push/pop label (IP<=>MPLS), assign FEC. **Flow:** LER push label => LSR swap => ... => LSR swap => LER pop label (back to ip). **Intrusion Detection/Protection System (IDS/IPS)** monitor network to allow real-time suspicious activity detection => immediat response. **Network-based:** monitor traffic on ntw segment. **Host-based:** monitor local logs/files/processes/traffic on a single host. **Hybrid:** combine both ntw+host view. **Behavioural:** detect deviation from learned normal behavior (anomaly-based). **Warning: acting on identified threat can impact production.** **Zero Trust** All data/computing services = rsc. No implicit trust based on ntw location, secure every comm. Access granted per-session, via dynamic policy (behavioral/environmental attributes). Authentication/authorization strictly enforced, re-checked dynamically. Continuously monitor asset/ntw integrity to improve security posture. **Open Platform Communications Unified Architecture (OPC UA)** standard for industry 4.0 convergence (cyber, physic, human, logistic, sell, etc.). Standardized access to all components, Manufacturer-independent data exchange, platform independent. Rich/extensible info model (complex types). **state of art native security, support** (vs Modbus: no native security). **Modes:** Client-Server, Publisher-Subscriber (PubSub). **IEC 61850** standard for defining devices within substation automation sys and how their interactions. **Platform for:** comm, protection, control, automation, measurements, recording, monitoring. **Features:** self description (interrogation), fast peer-to-peer (tripping/blocking/interlocking), reduce hard-wired connections, reporting. **Standardizes:** design, language, services, protocol, config, substation/device info, naming convention, fault records, conformance tests. **Protocols:** MMS, GOOSE, Sampled Values (SV). **Product Lifecycle Management (PLM):** Ensure that every involved person has access to inf about all process. **1) Idea:** New ideas based on market research. Creative/Structured phase to determine if product can succeed => Understanding client needs and market trends. **2) Design:** Detail specifications, plans and prototypes. Ensure its functional and feasible. Need versioning => Make product appealing **3) Manufacturing:** Design to product. Include sourcing materials, setting up production lines, quality control. Design data is integrated to manufacturing process to keep errors low and improve efficiency => Ensure data meets brand promise and quality standards **4) Service&Maintenance:** Distribution, customer services, maintenance, track product perf and customer feedbacks to improve product => Ensure customer satisfaction and enable longer product lifespan. **5) Disposal:** Safe/responsible disposal/recycling. According to regulations and sustainability practices. **Product Cybersecurity Lifecycle Secure Product Development:** Secure Product => Security Planning&Classification => Threat Modeling&Risk Assessment => Security Requirements => Security Architecture&Design => Secure Sourcing => Secure Implementation => Security Testing =>

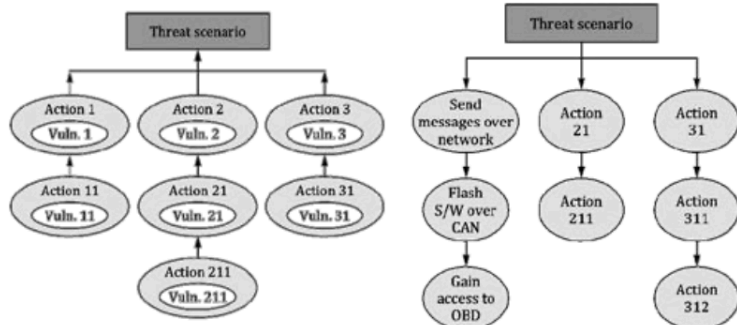
Security Documentation => Security Certifications => DevSecOps => back to Secure Product. **Post Launch Product Security:** Secure Product => Secure Deployment&Operation => Security Maintenance/Patching => Configuration Management => Vulnerability Management => Information Sharing => Customer Security Collaboration => Security Monitoring => Threat Intelligence => Incident&Crisis Handling => Secure End of Life => back to Secure Product. **Foundations:** Cyber Security Management System(s); Development&Production Security/Security Risk Management; Org Culture Awareness&Training/Supply Chain Security. **Activities within a Company Development:** Requirements (Requirements Mgmt) => Design (Architecture/Design Reviews, Defense in Depth, Product Composition definition, Procurement) => Implementation (Code Analysis/Reviews, Secure Coding Standards, Hardening, Procurement) => Testing (Verification, Automated Security Testing, Penetration Testing, OSS Identification) => Launch (Release Clearance, Code Signing, Customer Security Doc.) => **Manufacturing** => Production (Key Provisioning, Logistics) => **Operation** => Issue management (Supported: Update/Vulnerability Mgmt; Issue Mgmt: Incident Mgmt; Obsolete: Decommissioning). **Continuous (full lifecycle):** Threat Modeling; Secure Environment&Infra/Information Security/Human Risk Mgmt; Roles&Responsibilities/Training/Sharing/Evangelizing; Risk Mgmt/Governance Definition/Metrics. **Software Bill Of Material (SBOM): Why:** trust in digital infra should be proportional to its transparency, lack of it increases cyber risk + dev/procurement/maintenance cost. **Minimum content:** org/person that created artifact, used tool to generate SBOM, timestamp SBOM generation, component name, component version, UUID, relationship with other component. **More requirements:** Frequency (update on any change), Depth (all direct+indirect dependencies), Known Unknowns (state if info missing/why), Distribution&Delivery (machine+human readable, accessible to customer), Access Control, Accommodation of Mistakes (standard still evolving). **Secure Boot** HW-backed root of trust: each boot stage verifies signature/crypto key of next stage before executing (Boot ROM => U-Boot SPL => U-Boot => Linux Kernel => Application). **Challenges:** vendor-specific (NDA to access docs), key management (on/off device), key rotation, OSS licences (GPL), 3rd-party app integration. **Supply Chain Risk Management** Applies to IT+OT+IoT. Manages cyber risk from ICT/OT products, services, suppliers, sys integrators, service providers. **Process:** Threats (adversarial: malware/espionage/disruption; non-adversarial: disaster/poor quality/regulatory) x Vulnerabilities (external: supplier interdependencies; internal: unpatched sys, lack of awareness) => Likelihood => Impact (degree of harm) => Risk. **Symmetric vs Asymmetric Crypto** **Symmetric:** 1 shared secret key. **key distribution problem:** nb of keys grows with square of nb of entities ($n(n-1)/2$). **Asymmetric:** key pair (public/private), solves distribution problem. **Use of Public Key:** 1) decrypt a signature to validate signer's identity (signer used private key) 2) encrypt content that only matching private key owner can decrypt (confidentiality). **Digital Signature** Guarantee integrity and authenticity of data. **Sign:** 1) hash message => fingerprint 2) encrypt fingerprint with signer's private key => signature, attach to message. **Verify:** 1) recompute hash of received message => fingerprint A 2) decrypt signature with signer's public key => fingerprint B 3) compare A=B => valid (intact + authentic). **Certificate X.509** Digital certificate to authenticate entity and encrypt messages. Link btwn entity and its public key <= attested by trusted third party. **Content:** Common name (unique name of entity, can be wildcarded; Subject Alt Names = other DNS names covered), Issuer name (=> chains up to Root CA), Entity public key (algorithm/size), CA signature, Serial Number, Validity, Fingerprints (SHA-256/SHA-1), Key Usages/Extended Key Usages (e.g. Server/Client Auth). **Extensions (v3):** Authority Key ID (CA's key to verify sig), Subject Key ID, Key Usage, CRL Endpoints, Authority Info Access (OCSP/CA Issuers). **Hierarchy:** Root CA (self-signed, top of hierarchy, long validity 10-30yrs, can be stored in browsers/OS) => signs Intermediate CA => signs end-entity Certificate. **Public Key Infrastructure (PKI)** Set of HW/SW/policies/procedures to create/manage/store/distribute/revoke certificates. **Mechanism:** Registration and publication of certificates. Storage and distribution of certificates. Certificate revocation and status checking. **private sym/asym key must be confidential/authentic ; pub key must be authentic !**



Certificate Authority (CA) Publish and renew certificates as well as to create revocation lists. Entire trust is based on it. Anyone can become a CA

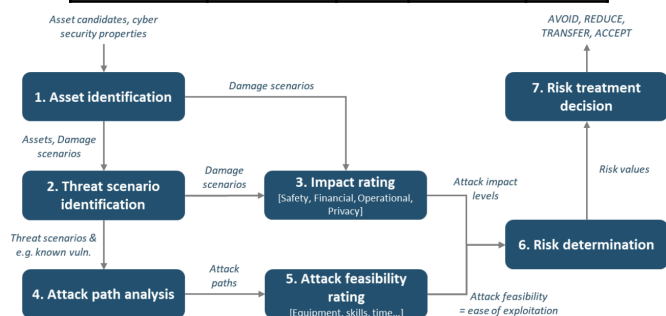
(defined by root certificates) **Certificate Revocation List (CRL)** Certificate has a limited validity period. Revocation if compromised key. Contains list of serial numbers of revoked certificates (signed by CA) **Registration Authority (RA)** Manage certificate requests: Storing them, verification with credential, communicating with requesting entity to establish identity/verify compliance, publishing revocation lists. **Validation Authority (VA)** Provide a certificate verification service **Certification practice** CA must describe process used to issue a certificate in document called **Certification Practice Statement**. More CA invests in verifying identity of entity, more secure/expensive certificate. **Extended Validation (EV)** most hard to obtain => Verification of legal/physical entity and operational presence of entity. Verification that entity has rights on required domain. Notarized confirmation of entity and its rights. **Reducing lifespan:** Enhanced security (limite private key exposition and impact if compromised), encourage automation and best practices adoption. Prepare for post-quantum challenges. **CRL deployment in OT:** host CRL internally, plain HTTP not HTTPS (else checking CRL server's own cert could itself require CRL = circular dependency), automate generation. **Hard-fail** (reject if can't verify, prioritize security) **vs Soft-fail** (proceed if can't verify, prioritize availability). Air-gapped/segmented OT often can't reach CRL server live => need offline distribution (e.g. preloaded/manually updated CRL). Monitor/alert on revocation infra health (CRL not regenerated, server unreachable, device check failures). **OT-specific:** OT protocols (Modbus, OPC UA, DNP3 w/ TLS) have varying support for cert validation/revocation checking, some ignore CRL entirely => test with real devices. **IEC 62351-9:** certificate management guidance for power sys. Change management in OT more rigid => plan renewals around maintenance windows, validity periods need runway for delayed updates. **IT/OT Security vs. Product Security:** **IT/OT:** stakeholders=internal actors&suppliers, goals=business continuity/resilience, regulatory=NIS2/GDPR. challenges=standard IT practices vs OT, asset heterogeneity/legacy, patch mgmt, not just a cost center. **Product security:** stakeholders=integrators&end users, goals=product liability, regulatory=legally binding for digital products sold in EU. challenges=integrate cybersec into dev/operation process, transversal to org units, compliance complexity, decommissioning responsibility unclear. **Common:** same foundations, products increasingly connected => policies cross IT/OT/Product domains. **Security Principle Holistic approach:** tech measure alone often not sufficient => think Technologies/Human factors/Processes together, on top of Risk Management, framed by regulatory framework. **Security by design:** integrate security measures&controls from beginning of dev. Apply where/when/how it matters (pragmatic, not everywhere). Most efficient way to reduce risk levels down to an acceptable level. Keep up-to-date visibility over current threat landscape. **Secure the weakest link:** how to identify it? if a vuln affects a control, how does it impact overall risk (which risks affected)? most effective way to mitigate once identified? **Defense in depth:** is 1 control enough? which layer mitigates which risk? how many weaknesses acceptable before risk increases? (layers: Physical, Perimeter, Network, Equipment, Application, Data). **Fail secure:** identify essential/safety functions, consider conflict w/ other discipline. **Assume secrets not safe:** treat secret exposure as realistic threat, evaluate impact if compromised, forget security-by-obscurity, enforce lifecycle controls (key rotation/expiration, secure update). **Monitor & audit:** supports forensic readiness, drives integrity/trust in audit data, monitoring = a security measure itself. **Proportionality & Precautionary:** quantify risk to enable proportional response, avoid "one-size-fits-all" (=same security everywhere), justifies decisions (traceability), balance security vs constraints (performance/cost/usability). **Threat analysis & Risk Assessment (TARA)** Defining and prioritizing what must be protected based on risk and threat analysis. What are my key assets & what potential consequences / damages ? What are attack vectors against my assets ? How & on what invest effort to reach a reasonable security posture ? What security measures for which improvement ? What to monitor for securing a continuous acceptable residual risks ? What security principles are we willing to follow ? Key tool to understand cs risk and support risk-informed decision-making. Mandatory in multiple regulations: products with digital elements (EU Cyber Resilience Act, Radio Equipment Directive, Machinery Directive), critical infrastructure (EU NIS2), also medical/automotive, and in Switzerland (ICT minimum, mandatory for gas/energy producers and distributors). Must be integrated into Software Development Life Cycle, as early as possible. Must be challenged and updated, it is a living document. **Challenges:** lack of cs competences across orgs, lack of a general cs strategy leading to inconsistencies (missing initial assumptions and rationales, bias from considering existing protection measures), weak maturity of tooling and software support, need for stakeholder interactions (interfaces with other risk assessments such as quality or functional safety, interfaces btwn IT-Security/OT-Security/Product-Security, RASIC roles: Responsible/Accountable/Supportive/Informed/Consultative), and maintenance complexity (risks continuously evolve, vulnerability considerations must be integrated during operation phase too). **After TARA:** document and implement security measures against known threat catalog, verify their effectiveness through Verification (did we build it right?) and Validation (did we build right thing?), review TARA after each feature update, context change, new threat, new attack feasibility, or new vulnerability, and document each accepted or transferred risk for traceability (why it was accepted, to whom and why it was transferred and what must

be checked, how it was reduced, how it was avoided). **TARA Process:** 1) **System and Assets Definition:** clarify product function/goals, which assets and cs attributes matter if compromised, assumptions about environment and adversarial conditions, architecture (product and sub-systems), communications (dataflows, technologies, inf exchanged), and trust boundaries (what is under company's control). 2.a) **Damage scenario, Impact rating and analysis:** is consequence of compromising a cs property of an asset (Authentication, Integrity, Confidentiality, or Availability; related triads are CIA and AAA). Impact rating uses SFOP categories (Safety, Financial, Operational, Privacy), each rated Severe, Major, Moderate, or Negligible. Analysis must be reproducible, trustable, and tailored to use-case. 2.b) **Threat scenario:** identify high-level attack scenarios using STRIDE: Spoofing (breaks authenticity), Tampering (breaks integrity), Repudiation (breaks non-repudiation), Information disclosure (breaks confidentiality), Denial of service (breaks availability), Elevation of privilege (breaks authorization). 3) **Risk values and treatment:** compute risk value, then take a risk-based treatment decision (avoid, transfer, mitigate, or accept). 2.a) **Attack trees** Threat scenarios are analyzed to describe possible attack paths. **Top-down:** attack trees, attack graphs, or taxonomy mnemonic-based approaches such as STRIDE, useful in concept and development phases when implementation is not yet available, or when building attack hypotheses. **Bottom-up:** based on output of a vulnerability analysis, used when an implementation is already available, to confirm hypotheses. **Combination:** mix of both approaches.



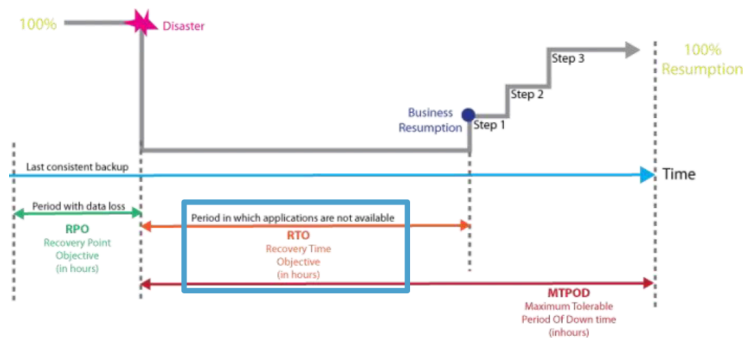
2.a) **Attack feasibility** For each attack path, feasibility is rated High, Medium, Low, or Very Low, using one of three methods: **Attack vector-based:** based on predominant attack vector of attack path, a basic approach useful for an early-stage assessment. **CVSS-based:** based on exploit metrics group (attack vector, attack complexity, privileges required, user interaction), formula $E = 8.22 \times V \times C \times P \times U$. **Attack potential-based** (ISO/IEC 18045 factors): elapsed time, specialist expertise, knowledge of item or component, window of opportunity, and equipment. 3) **Risk Matrice** A risk matrix maps impact level and attack feasibility to a risk value. **Purpose:** support risk treatment decisions including selection of controls, prioritize risks for treatment, report to stakeholders, and monitor risk over time. **Treatment options:** avoid risk (remove risk source), reduce risk (identify security measures), share or transfer risk (e.g. through contracts or insurance), or accept or retain risk. When a risk is accepted or transferred, rationale must be documented as a cs claim, subject to validation and monitoring.

	Very Low	Low	Medium	High
Severe	2	3	4	5
Major	1	2	3	4
Moderate	1	2	2	3
Negligible	1	1	1	1

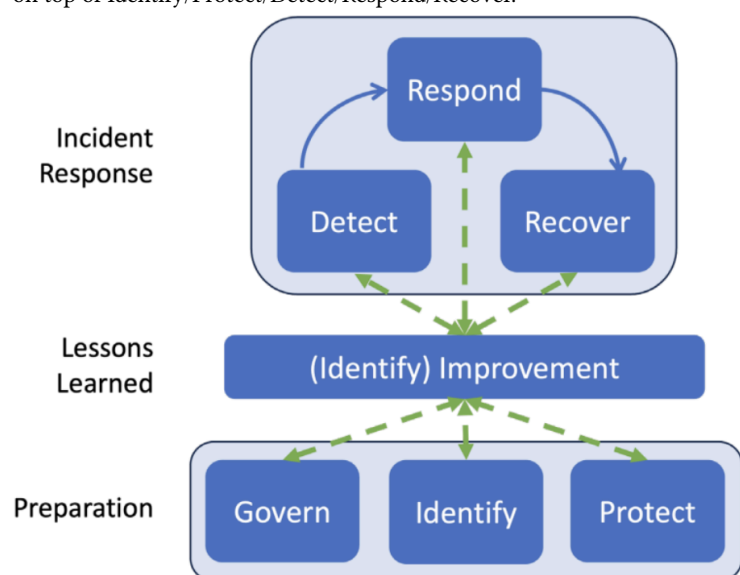


TARA Process Review Checklist for evaluating a “good job” in threat model documentation. **Completeness:** is all information in STRIDE or attack tree analysis complete, are strongest possible mitigations identified, are gaps understood? **Clarity:** is each threat and mitigation clearly explained for intended audience? **Specificity:** is each element at right level of detail (naming a protocol may be enough, or version and configuration may be needed)? **Traceability:** are relationships btwn components easily traceable, are identifiers consistent and not duplicated? **Consistency:** does documentation match actual implementation of manufactured device? **Roles and responsibilities:** are they clearly identified when discussing risk? **Assumptions:** are they clearly identified and reasonable? **Rationales:** are decisions justi-

fied in enough detail, especially when a risk is accepted or transferred? **Contingency Plans (CP)** Identified services provided by essential sys are able to operate without excessive interruption. Establish plans/procedures/measures unique to each sys to prevent/recover. **Goals:** Restore normal modes of operation with minimal cost and disruption to normal business activities after an adverse event. **CP Type:** Incident Response Planning (IR), Disaster Recovery Planning (DR), Business Continuity Planning (BC), Crisis Management Planning (CM). **Cost Balance Point:** Intersection btwn Cost to Recover and Cost of Disruption. **Incident** adverse event beginning to attack org against its cs assets, which has a realistic chance of success to threaten CIA of information assets/ other resources. **Incident Response Plan (IRP)** Preparation for/detection of/reaction to/recovery from incident (Event => Adverse Event => Incident). **Incident Response Planning Team (IRPT):** led by CISO/cs manager, with heavy presence of cs/IT/OT people/non-technical members. **Incident Response Policy:** contain a statement of management commitment, purpose/obj of policy, scope (to whom and what it applies under what circumstances), definition of cs incidents/related terms, organizational structure/definition of roles, responsibilities/levels of authority, requirement to report certain types of incidents, prioritization/severity ratings of incidents, performance measures, reporting/contact forms. **Incident Response Plan elements:** mission, strategies and goals, senior management approval, approach to incident response, communication strategies, metrics for measuring incident response, roadmap for maturing incident response. **Incident Response Plan procedures:** set of actions to take during incident/after incident is contained/before incident even occurs. **CERT vs CSIRT:** CERT (Computer Emergency Response Team) takes proactive measures to prevent incidents/enhance security, works at national/organizational level, focus prevention/preparedness, favorize communities of practice for knowledge sharing. CSIRT (Computer/Cyber Security Incident Response Team) reacts to security incidents within an org, typically focused on specific org/sector, focuses immediate response/remediation, builds internal capabilities to enhance organizational security awareness. **CSIRT Liaison:** liaison btwn org and CSIRT, it allows anyone to report suspicious activity. **Incident Response Actions:** detection of incident that is underway and notify CSIRT, reaction of CSIRT to incident by activating IR plan and selecting appropriate response strategy, recovery phase where CSIRT works with rest of company to restore normal operations. **Disaster Recovery Plan (DRP)** Prepares for and recovers from natural/man-made disasters. Recovers/purchase/replace assets from appropriate sources. Reestablishes functional assets at primary site/new one. **Business Continuity Plan (BCP)** Ensures that critical business activities can continue if a disaster occurs, by relocating core functions to temporary facility. Managed by CEO/COO, and activated shortly after Disaster Recovery Plan. **Crisis Management Plan (CMP)** Focuses protecting human health/welfare, managing crisis itself, supporting employees/guests, keeping public informed, communicating with major stakeholders. **CP Methodology** 1) Form CPMT 2) Develop CP policy 3) Conduct BIA 4) Form subordinate planning teams 5) Develop subordinate planning policies 6) Integrate BIA 7) Identify preventive controls 8) Organize response teams 9) Create response strategies 10) Develop subordinate plans 11) Ensure testing, training and exercises **Contingency Planning Management Team (CPMT) Responsibility:** Obtaining commitment from senior management, Managing and conducting overall process, Writing master CP document, Conducting BIA, Organizing/staffing subordinate teams (both planning/response teams), Providing guidance to and integrating work of subordinate teams. **CP Policy** Document that mandate to do CP (above IR/DR/BC/CM plans). **Content:** introductory statement on why CP matters, scope/purpose of CP, call for periodic risk assessment and BIA, definition of major CP components, identification of individuals responsible (clearly defined roles), guidance for selecting recovery options/BC strategies, requirement to train/exercise/test plans, identification of key laws/standards/regulations, call to regularly challenge org assumptions. **Business Impact Analysis (BIA)** Assess mission/business process and recovery criticality, Identify resource requirements/recovery priorities => Use time criticality of functions/processes to guide prioritization. **Recovery Point Objective (RPO):** maximum acceptable level of data loss following an unplanned event (time btwn last consistent backup and disaster). **Recovery Time Objective (RTO):** time business process could be unavailable before business operations are significantly impaired. **Maximum Tolerable Period Of Downtime (MTPOD):** duration after which org viability would be irrevocably threatened if product/service delivery cannot be resumed. **Inputs to BIA data collection:** Risk assessment, IT/OT applications/logs, audit/financial reports. **BIA in OT:** fails when lack of cross-functional input (engineering/operations/OT maintenance), failure to capture indirect dependencies, lack of understanding that IT time-based assumptions do not apply to OT (an RTO multiple hours may be fine in IT but 5 minutes downtime can have significant impact on OT). Modern OT BIA must identify critical processes and functions, not just sys, map technical dependencies/operational tolerances, quantify cross-site impacts for multi-site operations, incorporate recovery thresholds informed by real scenarios, not just SLAs. **BIA Content:** ID/Business Activity/Activity Owner/Category/Area of Impact/RTO/RPO/MTD/Priority/Recovery Approach/Resources needed/References



NIST Cybersecurity Framework **Identify** understand cs risks **Protect** develop/implement safeguards to guarantee services **Detect** develop/implement activities to identify occurrence of cs event **Respond** develop/implement activities to take action regarding detected event **Recover** develop/implement appropriate plan to maintain resilience and restore capability disrupted by cs event. **Govern** org's cybersecurity risk management strategy, expectations and policy are established, communicated and monitored, on top of Identify/Protect/Detect/Respond/Recover.



NIST Handling Checklist classic incident handling lifecycle, after preparation. **Detection and Analysis:** determine whether incident occurred (analyze precursors/indicators, look for correlating information, perform research, document investigation and gather evidence as soon as incident is suspected), prioritize handling based on impact, report incident to appropriate internal/external parties. **Containment, Eradication, and Recovery:** acquire/preserve/secure/document evidence, contain incident, eradicate it (mitigate exploited vulnerabilities, remove malware, repeat detection steps if more affected hosts are discovered), recover from incident (return affected sys to operationally ready state, confirm they function normally, implement additional monitoring for future related activity if needed). **Post-Incident Activity:** create follow-up report, hold lessons-learned meeting.